Threat Actor Profile

APT ShinyHunters

I. Résumé exécutif 3
II. Méthodologie d'investigation 4
Démarche d'enquête 4
Sources ouvertes exploités 4
Mesure de fiabilité et validité de l'information 4
III. Présentation de ShinyHunters 5
Contexte d'apparition 5
Historique des activités connues 6
Motivations 8
Structure 8
Membres 9
Création et première phase (V1) 10
Deuxième phase (V2) 10
Troisième phase (V3) 11
Pression judiciaire et passation de relais 11
Nouvelle ère et rebranding (V4) 12
Désaveu des fondateurs 13
Situation à date 13
IV. Infrastructure et empreinte numérique 14
Domaines 14
Adresses IP 15
Corrélations techniques 15
Hébergeurs (Bulletproof) et outils identifiés 15
Méthodologie d'attaques 16
V. Comportements et traces numériques 16
VI. Analyse linguistique et identification 17
Recoupement entre pseudonymes, alias et profils associés 17
Analyse linguistique 19
Etude syntaxique et stylistique des messages publics 19
VII. Réseau relationnel et partenariats 19
Identification d'acteurs affiliés ou collaborateurs 19
Cartographie des connexions 20
Degré d'influence et hiérarchisation du réseau 20
VIII. Analyse technique et TTP (ShinyHunter OG) 21
Techniques observées 21
Outils identifiés 21
Monétisation 21
Référentiel MITRE ATT&CK 22
IX. Evaluation analytique : 23
Interprétation des données recueillies 23
Annexes 24

I. Résumé exécutif

Ce rapport présente une investigation portant sur ShinyHunters, un nom longtemps associé à la fuite et à la revente de bases de données issues de compromissions à grande échelle. L'objectif de ce travail est de comprendre comment ShinyHunters a évolué dans le temps, d'identifier ce qui se cache réellement derrière ce nom et de clarifier les nombreuses confusions actuelles liées à son utilisation. L'enjeu principal est de faire la différence entre le groupe d'origine et les versions plus récentes qui utilisent ou revendiquent encore l'appellation ShinyHunters.

L'analyse repose uniquement sur des sources ouvertes, notamment des forums underground, des plateformes de leak, des communiqués publics et des échanges observés au sein de l'écosystème cybercriminel. Dès le départ, l'hypothèse principale était que ShinyHunters ne correspond pas à un groupe unique et stable, mais plutôt à un nom réutilisé par différents acteurs au fil du temps. Il était également supposé que la structure du groupe était informelle, et que ses motivations avaient évolué, passant d'une logique au départ surtout financière à une recherche plus marquée de visibilité et de reconnaissance. Enfin, l'investigation partait du principe que certaines activités récentes attribuées à ShinyHunters pouvaient en réalité être le fait d'acteurs distincts, en particulier autour de la réouverture de BreachForums.

Les résultats confirment que ShinyHunters n'a jamais réellement fonctionné comme un groupe organisé de manière classique, mais plutôt comme un nom utilisé pour signer et revendiquer des fuites de données. Le noyau fondateur, actif à partir de 2020, était restreint, collaborait peu avec d'autres groupes et poursuivait avant tout des objectifs financiers simples et rationnels. Avec le temps, les arrestations, les enquêtes judiciaires et les départs ont entraîné une fragmentation progressive. La version d'aujourd'hui, souvent présentée comme ShinyHunters n'a plus de lien direct avec le groupe d'origine, à l'exception de Kelotex (aka James). Les autres acteurs associés à cette phase récente viennent principalement de sphères proches de Scattered Spider et Lapsus$, ce qui rend l'appellation SLSH plus adaptée pour décrire cette nouvelle configuration. Le rapport met également en évidence une forte confusion autour de la réouverture de BreachForums, régulièrement attribuée à tort à ShinyHunters en raison d'un ancien lien de propriété avec le groupe historique, alors que les acteurs impliqués n'ont jamais fait partie de ShinyHunters ni revendiqué ce statut. L'ensemble de ces éléments montre que ShinyHunters doit aujourd'hui être compris non pas comme un groupe cohérent, mais comme un nom repris, disputé et réutilisé, au cœur de rivalités et de malentendus persistants.

II. Méthodologie d'investigation

Démarche d'enquête

1. Collecte passive sur forums
2. Analyse des leak databases
3. Corrélation des pseudonymes et identités (Doxbin + Tracked.sh)
4. Analyse temporelle des publications
5. Validation croisée des sources

Sources ouvertes exploités

- Forums: BreachForums, RaidForums, DarkForums, Zone-h
- Bases de données: HIBP, Shodan, VirusTotal, Breach.vip, Tracked.sh
- Articles d'investigation: GTI (ex Mandiant), Intel471 et articles de presse
- Identification : Twitter, Github, Doxbins, Breach.vip, Intel471 et GTI

Mesure de fiabilité et validité de l'information

Les informations retenues ont systématiquement été croisées entre plusieurs sources indépendantes. Les éléments confirmés par des rapports CTI (Mandiant, Intel 471, GTI) ont été considérés comme hautement fiables. Et les revendications non corroborées ont été traitées comme hypothèses ou associations probables.

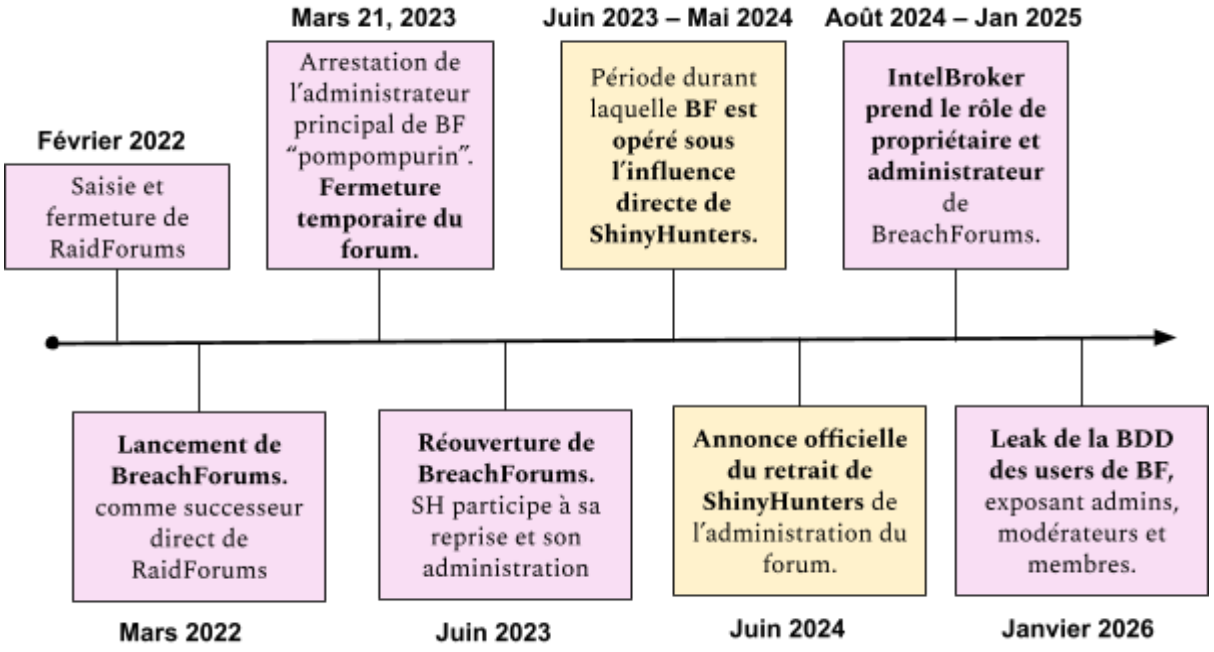
III. Présentation de ShinyHunters

Contexte d'apparition

ShinyHunters apparaît dans l'écosystème cybercriminel vers début 2020 (mai 2020) et son apparition marque une rupture avec les trajectoires classiques d'évolution des collectifs de hackers. Traditionnellement, ces groupes observent une phase de montée en puissance graduelle, débutant par des intrusions de faible envergure pour éprouver leurs méthodes et asseoir leur crédibilité dans le domaine.

À l'inverse, ShinyHunters a opté pour une stratégie de notoriété immédiate. En l'espace d'une seule semaine, le groupe a publié les bases de données exfiltrées de onze entreprises d'envergure internationale (parmi lesquelles figurait Tokopedia, Wish ou encore Homechef), exposant ainsi les données personnelles de plus de 73 millions d'utilisateurs. Cette offensive éclair, caractérisée par une volumétrie de données inédite pour un nouvel acteur, lui a permis de s'imposer instantanément comme un acteur majeur sur les forums de revente de données comme RaidForums.

À partir de 2023, ShinyHunters ne se limite plus aux fuites de données et s'implique directement dans l'infrastructure de l'écosystème cybercriminel. Après l'arrestation de l'administrateur historique de BreachForums, le groupe participe à la reprise et à l'administration du forum, qui devient le principal successeur de RaidForums. Entre juin 2023 et mai 2024, ShinyHunters joue un rôle central dans le fonctionnement de la plateforme, avant d'annoncer son retrait.



Et encore très récemment, leurs noms continuent de revenir dans l'actualité mais cette fois avec un angle différent. On parle davantage de social engineering, notamment du vishing (arnaque par téléphone), parfois boosté par des méthodes plus modernes (clonage de voix / intelligence artificielle selon certains articles).

Historique des activités connues

La phase d'émergence (2020) :

Cible	Impact estimé
Tokopedia	91 millions de comptes
Wattpad	271 millions de comptes
Microsoft (GitHub)	500 Go de code source
Wishbone	40 millions de comptes
Zoosk	30 millions de profils
Unacademy	22 millions de comptes
Animal Jam	46 millions de comptes
HomeChef	8 millions de comptes
Minted	5 millions de comptes
Chatbooks	15 millions de comptes

Expansion et vagues successives (2021 - 2023) :

Cible	Impact estimé
Nitro PDF	77 millions de comptes
Pixlr	1,9 million de comptes
Bonobos	7 millions d'emails
BigBasket	20 millions de clients
Dave (via Waydev)	7 millions d'utilisateurs
Juspay	100 millions de transactions
BuyUCoin	325 000 utilisateurs

La campagne historique Snowflake (2024)

Cible	Impact estimé
Ticketmaster	560 millions de clients
Santander	30 millions de clients
Advance Auto Parts	380 millions d'entrées
AT&T	110 millions d'abonnés
LendingTree / QuoteWizard	190 millions d'entrées
Neiman Marcus	31 millions de clients
TruistBank	Données clients et employés

La campagne SaaS et Salesforce (2025)

Cible	Impact estimé
Google	Données CRM (SMB)
Qantas	5,7 millions de passagers
Disney/Hulu	Données marketing
LVMH	Bases clients régionales
Adidas	Tickets de support client
FedEx	Données CRM
Toyota	Données de vente et CRM
Air France-KLM	Données de fidélité

Motivations

Au départ, ShinyHunters fonctionne de manière très rationnelle : leur objectif est de gagner de l'argent en volant et en revendant des données. Leur nom lui-même reflète déjà cette logique de "chasse au trophée". Le terme Shiny, semble venir de l'univers Pokémon, dans lequel il désigne quelque chose de rare et convoité. Dès le début, l'idée n'est donc pas seulement de voler, mais de mettre la main sur des données qui ont de la valeur.

Avec le temps, on observe une montée en puissance progressive des cibles. Le groupe commence par attaquer des entreprises classiques, puis s'oriente vers des sociétés de plus en plus connues et visibles à l'échelle internationale. Les fuites associées à de grandes marques et à des groupes multinationaux deviennent une façon de prouver leur capacité.

Et ils ne s'arrêtent pas là. Les cibles finissent par inclure des acteurs bien plus sensibles, comme des fournisseurs de services essentiels, voire des entités proches du secteur public ou gouvernemental. À ce stade, l'enjeu dépasse clairement le simple gain financier. Le choix de ce type de cibles montre une volonté d'affirmer un pouvoir, de démontrer qu'aucune organisation n'est hors de portée.

Aujourd'hui, la motivation du "groupe" semble avoir évolué. Si, au départ, les fondateurs de ShinyHunters étaient surtout intéressés par l'argent, on a l'impression que les membres plus récents sont davantage motivés par la notoriété. Faire parler d'eux, viser des cibles très visibles et marquer les esprits semble devenu aussi important que le gain financier.

Structure

ShinyHunters ne semble pas fonctionner avec une structure hiérarchique , comme on peut l'observer chez de grands groupes de cybercriminels. Il n'y a pas d'éléments indiquant l'existence de rôles, de chefs identifiés ou de chaînes de décision formelles. L'ensemble donne plutôt l'image d'un groupe informel, proche d'un collectif d'amis qui travaillent ensemble de manière ponctuelle et opportuniste.

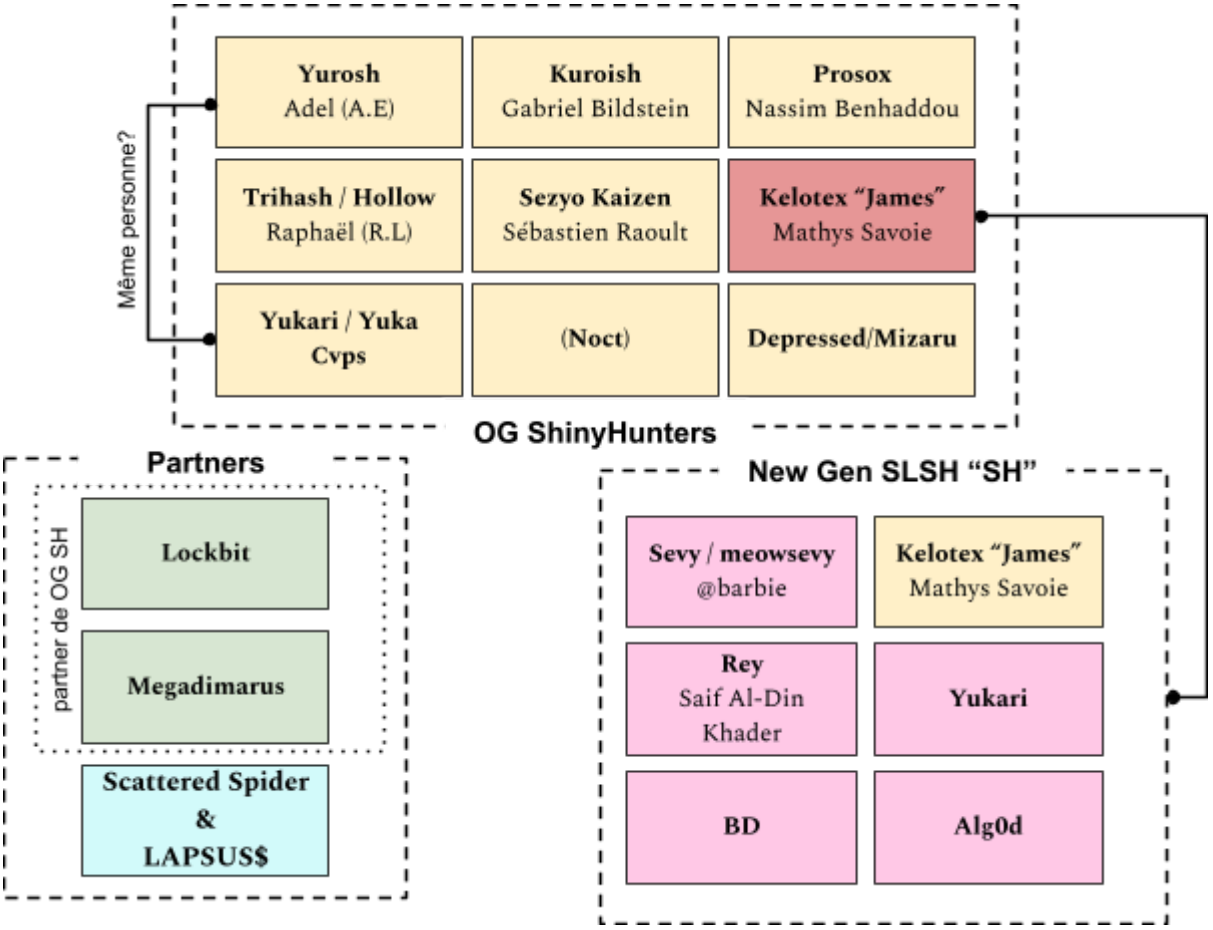
Les informations disponibles suggèrent que le groupe serait composé d'un noyau restreint, probablement autour d'une dizaine de personnes au maximum. Cette taille limitée leur permet de rester discrets, de se coordonner rapidement et de limiter les risques liés aux fuites internes ou à une infiltration par les forces de l'ordre. Le fonctionnement semble avant tout basé sur la confiance et les relations personnelles, plus que sur une organisation rigide.

Chaque membre apporte surtout ce qu'il sait faire, sans rôles officiels ou fonctions bien définies. Certains sont plus à l'aise avec la récupération de données, d'autres avec les environnements cloud ou l'analyse de dépôts de code. Ce fonctionnement assez libre leur donne beaucoup de flexibilité et leur permet de bouger vite quand une opportunité se présente.

Zone d'influence

ShinyHunters n'a pas de zone d'influence géographique précise. Le groupe agit à l'échelle internationale et touche des entreprises situées dans de nombreux pays, sans logique régionale particulière.

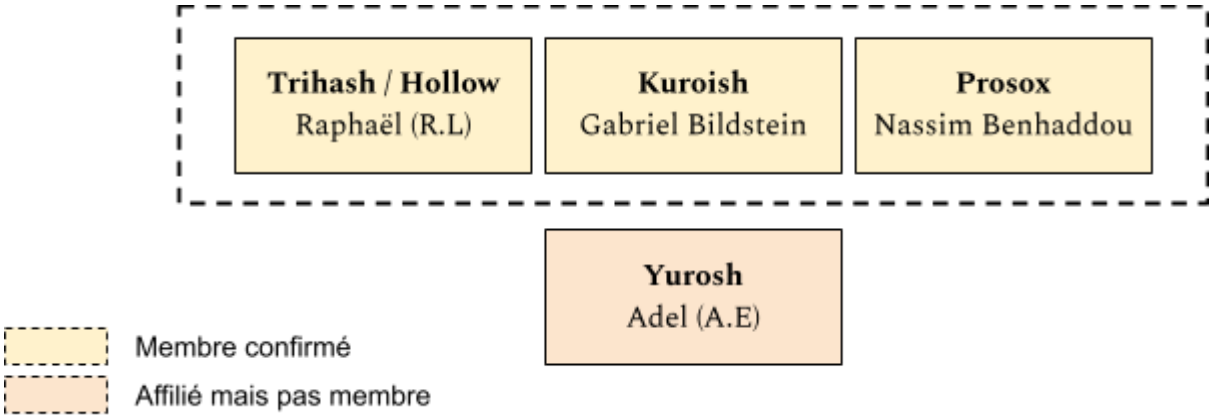
Membres



À l'origine, ShinyHunters n'est pas vraiment un groupe structuré, mais plutôt un nom utilisé pour signer des leaks. Ce nom a été repris par différentes personnes au fil du temps, avec des compositions qui ont évolué, certains membres ayant été arrêtés ou ayant arrêté leurs activités, tandis que d'autres ont repris le nom par la suite.

Il est donc plus pertinent de parler de plusieurs versions de ShinyHunters, plutôt que d'un groupe unique et stable. La chronologie ci-dessous permet de comprendre comment le nom ShinyHunters a évolué, ainsi que les raisons de ces changements.

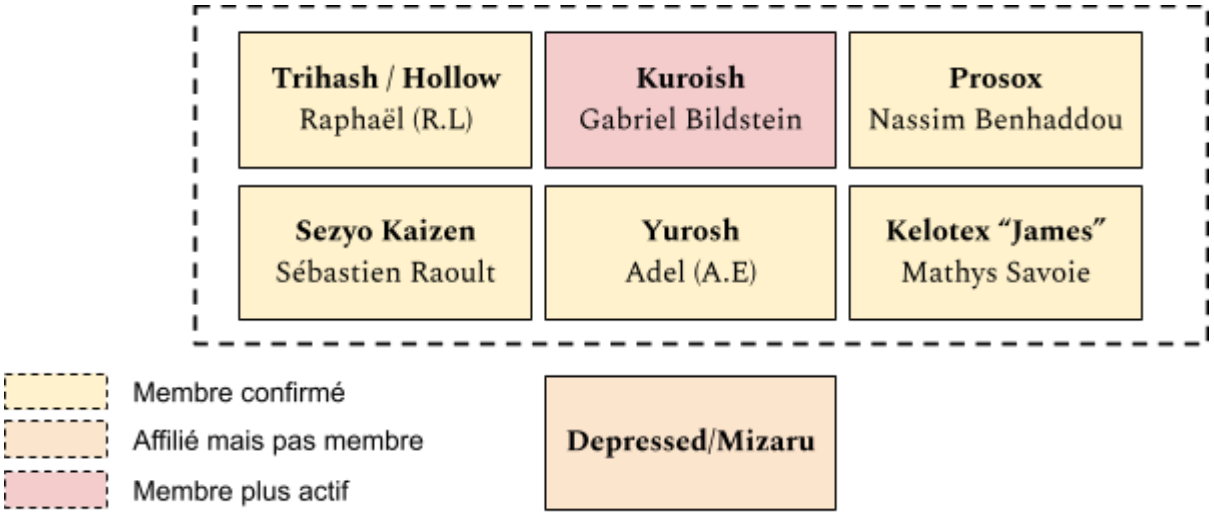
Création et première phase (V1)



En 2020, à sa création, ShinyHunters est composé d'environ trois personnes, avec un affilié qui n'est pas réellement membre du noyau dur, mais plutôt un ami participant de manière occasionnelle. À ce stade, on ne peut pas vraiment parler d'un groupe organisé : il s'agit surtout d'un groupe de potes utilisant le même nom pour signer leurs actions.

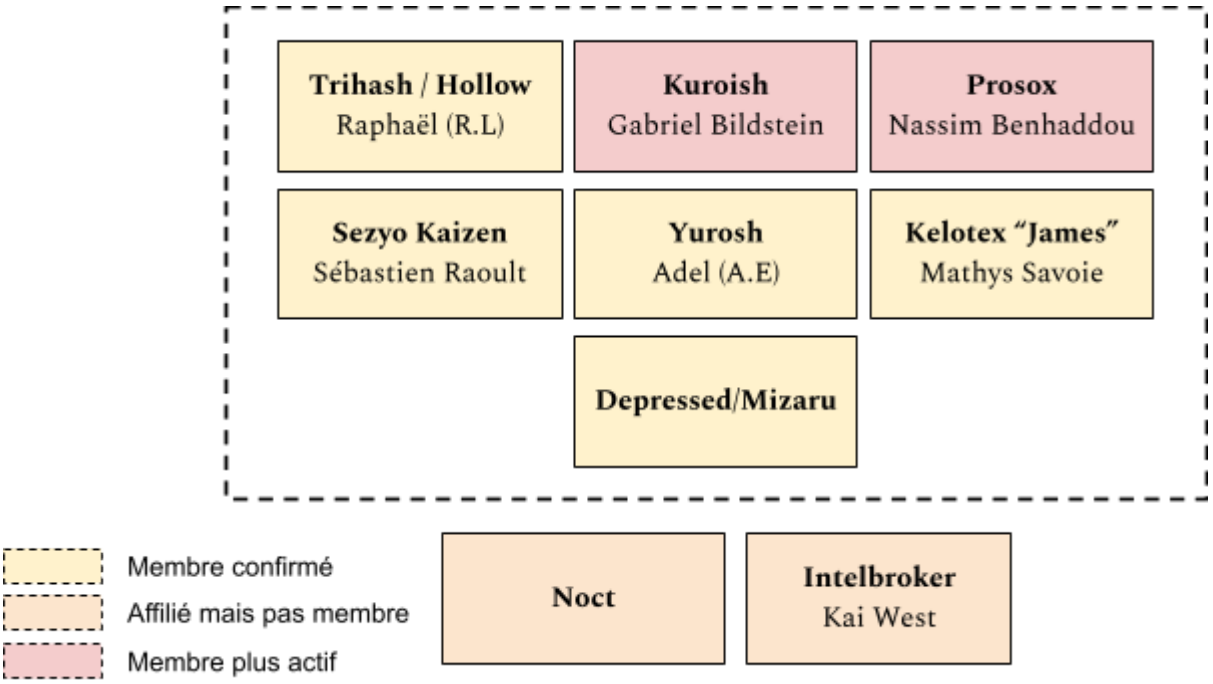
Cette période est marquée par quelques faits notables, notamment le hack du clip "Despacito" sur VEVO.

Deuxième phase (V2)



À partir de la V2, la composition commence à changer. Kuroish n'est plus actif dans le groupe, et son identité est ensuite usurpée par un autre acteur, connu sous les pseudonymes Dengisan R/Zambrius. Cette usurpation entretient encore davantage la confusion autour des membres réels de ShinyHunters.

Troisième phase (V3)



La V3 correspond à ce qui est souvent considéré comme la dernière "vraie" version de ShinyHunters, avant la reprise complète du nom et le rebranding mené par Kelotex (aka "James")". On y retrouve encore certains membres fondateurs, mais la dynamique du groupe commence à changer.

À noter que Noct, bien que parfois mentionné dans certains rapports d'investigation, n'a pas à être considéré comme membre de ShinyHunters. Il s'agirait plutôt d'un ami de Yuro, modérateur de BreachForums, mais pas impliqué directement dans les opérations. De la même manière, Prosox quitte le groupe à cette période.

Pression judiciaire et passation de relais

Après cette phase, plusieurs membres du noyau historique sont inquiétés par des enquêtes judiciaires, voire déjà arrêtés. Face à cette pression, beaucoup choisissent de se faire discrets ou d'arrêter complètement leurs activités cybercriminelles, afin de se protéger ou de réduire les soupçons à leur encontre.

Dans ce contexte, Trihash, qui se sent menacé par une arrestation imminente, décide de transmettre la clé PGP, servant à prouver leur identité, à Kelotex (alias "James").

L'objectif est double :

- permettre la continuité des publications sous le nom ShinyHunters,
- créer une forme de diversion pour laisser penser que les autorités n'ont pas arrêté les bonnes personnes, puisque les revendications continuent malgré les arrestations.

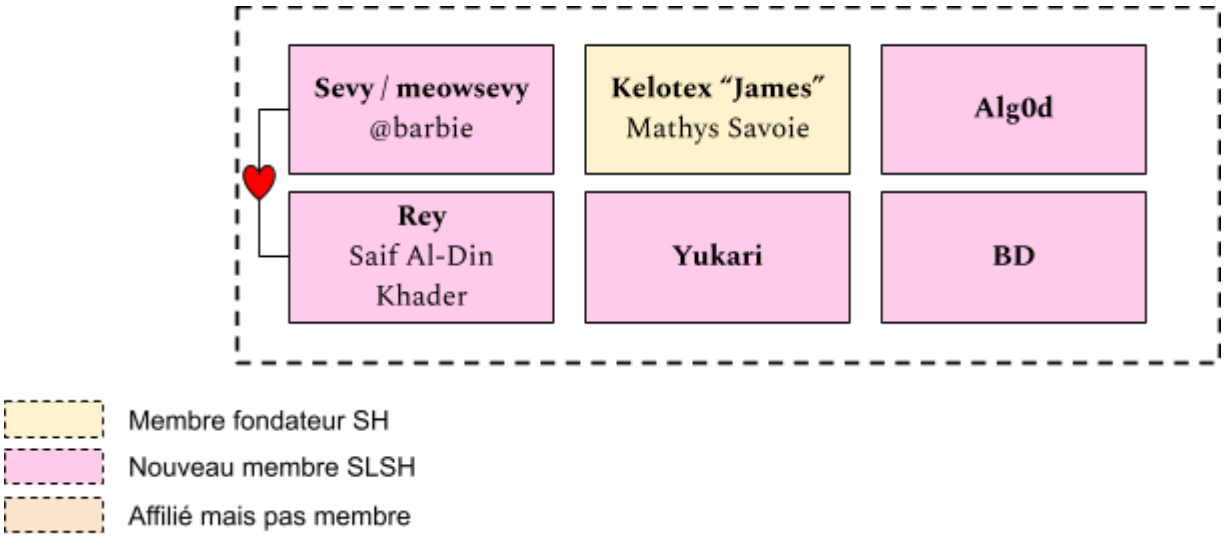
Cette passation de clé marque clairement un tournant.

Nouvelle ère et rebranding (V4)

Avec Kelotex à la manœuvre, on assiste à une nouvelle ère ShinyHunters. Les ambitions changent : les attaques deviennent plus mises en scène, les revendications plus scénarisées, avec des communiqués et une communication beaucoup plus travaillée. On parle ici davantage d'un rebranding, que d'une simple continuité du groupe initial.

Dans cette logique, Kelotex publie un message affirmant que plusieurs acteurs vont "disparaître", officiellement pour apaiser les tensions, mais aussi pour renforcer l'idée que les personnes arrêtées ne sont pas les véritables responsables des revendications :

"We LAPSUS$, Trihash, Yurosh, Yaxsh, WyTroZz, N3z0x, Nitroz, TOXIQUEROOT, Prosox, Pertinax, Kurosh, Clown, IntelBroker, Scattered Spider, Yukari and among many others, have decided to go dark. Our objectives having been fulfilled, it is now time to say goodbye."

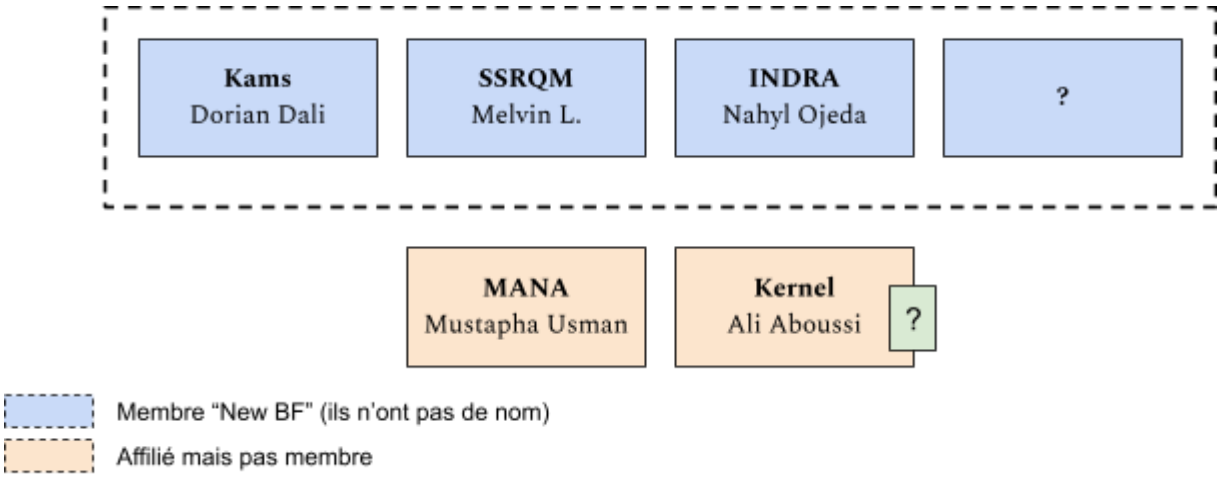


Désaveu des fondateurs

Il est important de préciser qu'à ce stade, les membres fondateurs de ShinyHunters se désolidarisent du nouveau groupe et ne soutiennent pas cette nouvelle version. Certains prennent publiquement leurs distances, indiquant ne pas reconnaître cette reprise du nom.

Situation à date

La situation autour de ShinyHunters continue d'évoluer et devient de plus en plus confuse. Les anciens membres prennent progressivement leurs distances, et il est important de préciser que le groupe aujourd'hui présenté ou décrit comme "ShinyHunters" n'a plus réellement de lien avec le groupe d'origine. À ce stade, il ne reste pratiquement plus que Kelotex (aka James) comme personne ayant réellement fait partie du noyau initial. Les autres profils associés à cette nouvelle version sont majoritairement issus de sphères proches de Scattered Spider ou Lapsus$. Pour cette phase récente, l'appellation SLSH semble donc plus appropriée que ShinyHunters, afin d'éviter toute confusion avec le groupe fondateur.



Avec la réouverture de BreachForums, un nouveau groupe, jusque-là assez discret, a été associé à tort d'être ShinyHunters. Cette confusion vient principalement du fait que BreachForums est passé, à un moment donné, entre les mains de ShinyHunters (le groupe originel), ce qui a conduit de nombreuses personnes à faire un raccourci lors de sa réouverture récente. En réalité, ce nouveau groupe n'a aucun lien direct avec ShinyHunters. Même si certains acteurs se connaissent ou évoluent dans des cercles similaires, ils n'ont jamais fait partie du groupe ShinyHunters et ne s'en sont jamais revendiqués.

Un autre élément clé de la confusion vient du fait que les acteurs impliqués dans la réouverture de BreachForums n'ont pas créé de nouveaux comptes, mais ont récupéré d'anciens comptes disposant déjà de droits élevés. Or, une grande partie de ces comptes appartenait à d'anciens membres de ShinyHunters.

Indra a notamment repris le compte Hollow/Trihash, membre fondateur de ShinyHunters. L'ancienne URL du compte de Trihash (https://breachforums[.]bf/User-hollow) dirige aujourd'hui vers le compte d'Indra, ce qui a entretenu l'amalgame. Il s'agit d'une reprise de comptes et d'autorisations, pas d'une continuité du groupe ShinyHunters.

Des profils comme Indra, Kams, actifs autour de BreachForums et à l'origine de sa réouverture très récente et du leak du ministère de l'Intérieur, sont aujourd'hui en opposition directe avec Kelotex (aka James). Cette opposition alimente encore davantage la confusion entre les différentes entités.

Ces tensions sont visibles à travers plusieurs communiqués publiés sur le site shinyhunters[.]rs, dont le contrôle est actuellement disputé entre le groupe d'Indra et Kelotex. Les échanges prennent la forme d'accusations publiques, de communiqués parfois agressifs, de menaces et dans certains cas, d'épisodes de doxing.

Kelotex affirme de son côté que les personnes impliquées dans la réouverture de BreachForums seraient des imposteurs, voire liées aux autorités. En réaction, il met en avant son propre site concurrent, Breachstar[.]io, présenté comme une alternative à BreachForums.

Enfin, certains profils comme MANA (Mustapha Usman) semblent affiliés à la réouverture de BreachForums, aux côtés d'autres acteurs encore difficiles à positionner clairement à ce stade, tels que Semtex/Warzax, Pupupuh ou Omar Benkachouzi. Les liens exacts entre ces individus restent flous et nécessitent encore des confirmations.

IV. Infrastructure et empreinte numérique

Domaines

- **shinyhunte[.]rs**
  Site de communiqués et leaks
  - Enregistré le 02/10/2025 | Statut : actif | Registrar : Webglobe d.o.o.
  - Contact admin/tech : Key-Systems GmbH
  - DNS : charles.ns.cloudflare.com / crystal.ns.cloudflare.com
- **breachforums[.]hn**
  - Utilisé lors de la reprise de BreachForums puis pour extorsion Salesforce
  - Saisi par le FBI (ns1/ns2.fbi.seized.gov) (.onion restée active après la saisie)
- Anciens domaines BreachForums (hébergement via DDoS-Guard)
  - breachforums[.]st / cx / is / vc
- Domaines de phishing
  - **bless-invite[.]com** (faux portail Okta)
    - Registrar : Tucows | Privacy : Njalla

Adresses IP

- **196.251.83[.]162**
  - Héberge bless-invite[.]com
  - ASN AS401120 (cheapy.host) | Localisation : Italie
  - Mentionnée dans alertes FBI (UNC6040)
- **185.93.3[.]195**
  - IP associée au compte ShinyHunters sur BreachForums
  - Probable sortie VPN / CDN (Datacamp / CDN77)
- IP citées dans rapports FBI / Mandiant
  - **198.54.130[.]108**
  - **206.217.206[.]14**
  - **208.131.130[.]53** (+ d'IP dans les annexes)

Corrélations techniques

- Réutilisation des mêmes :
  - hébergeurs, plages IP et configurations serveur
- Infrastructure fragmentée mais cohérente
  Rotation rapide des domaines et comptes à privilèges
  Usage systématique de services d'anonymisation

Hébergeurs (Bulletproof) et outils identifiés

- **DDoS-Guard** & **Shinjiru** : Ces hébergeurs (souvent situés en Russie ou en Malaisie) sont identifiés comme des piliers pour protéger leurs forums (comme BreachForums) et leurs sites miroirs contre les demandes de suppression légale.
- **Flokinet** : Utilisé pour héberger une partie critique de leur infrastructure de phishing, notamment les domaines usurpant des plateformes de code.
- **Delta Host** : Également cité comme prestataire favorisant l'anonymat pour leurs serveurs de commande et de contrôle (C2).
- **Cloudflare** : Le groupe masque systématiquement les véritables adresses IP de ses serveurs derrière le reverse-proxy de Cloudflare.
- **Mullvad VPN** : Les analyses techniques (notamment lors de l'attaque Salesforce) ont confirmé l'utilisation intensive de ce service VPN spécifique par les opérateurs pour masquer leurs IP résidentielles lors des phases d'intrusion manuelle.
- **Réseau Tor** : Utilisé pour l'administration backend de leurs infrastructures
- **Njalla :** Services de privacy WHOIS.
- **Cheapy.host :** VPS utilisés pour phishing

Méthodologie d'attaques

SLSH : Leur mode opératoire actuel combine ingénierie sociale assistée par IA et outils de phishing avancés. Voici la chaîne d'attaque complète reconstituée :

Reconnaissance et Vishing (hameçonnage vocal) : plutôt que d'attaquer les failles logicielles, ils attaquent les humains, souvent le support informatique (Helpdesk).

- Outils de clonage vocal (AI) : ils utilisent des plateformes citées ci-dessus comme Vapi ou Bland AI pour générer des voix synthétiques réalistes ou cloner celles de cadres dirigeants.

Phishing et Vol de Session (AiTM) : une fois la victime au téléphone ou contactée, l'attaque technique débute.

- **Evilginx & Reverse Proxy :** Ils déploient des attaques de type Adversary-in-the-Middle (AiTM) à l'aide du framework Evilginx. Cela leur permet d'intercepter non seulement le mot de passe, mais aussi surtout le cookie de session.
- **Typosquatting & Domaines leurres :**
  - L'infrastructure repose sur des domaines visuellement proches des cibles légitimes.
  - Exemple spécifique : Utilisation de domaines comme gjthub.com (imitant GitHub) ou des variantes comme company-salesforce.com.
  - Ces domaines sont majoritairement hébergés chez Flokinet pour éviter les fermetures rapides lors des campagnes actives.

Persistance et Exfiltration

- **Malicious OAuth Apps :** Une fois connectés (souvent sur des environnements Salesforce ou Okta), ils ne se contentent pas de voler des données : ils installent des applications connectées malveillantes ou utilisent des outils légitimes détournés (comme Salesforce Data Loader) pour maintenir un accès permanent via des tokens OAuth, même si la victime change son mot de passe.

Vishing (Vapi/Bland AI) -> Redirection vers Phishing (Evilginx) -> Domaine leurre (gjthub.com sur Flokinet) -> Vol de session + Installation App OAuth -> Exfiltration massive.

V. Comportements et traces numériques

Heures et fréquences de publication

- Publications majoritairement liées aux leaks, pas de rythme régulier
- Activité en rafale lors d'annonces de fuites ou de conflits internes
- Horaires variables, compatibles avec une activité internationale

Interactions

- Communication principalement unidirectionnelle lors des leaks
- Interactions fréquentes avec d'autres acteurs sur les forums (réponses, provocations, disputes)
- Utilisation de communiqués publics pour régler des conflits ou revendiquer des actions

Plateformes utilisées et habitudes

- Forums underground : BreachForums (.bf / .st), RaidForums (historique), DarkForums, Empire, WeLeakInfo
- Site vitrine et communiqués : shinyhunte[.]rs
- Réseaux sociaux : X / Twitter (@sh_corp), usage orienté visibilité et amplification médiatique
- Messagerie chiffrée : XMPP (shinyhunters@xmpp.jp / shinyhunters@xmpp.cx)
- Acceptation de dons via adresse Bitcoin publique : 1CGq1GQfqwi9VEUSzQux56FxpqNbayXM36

Corrélation temporelle

- Activité souvent corrélée à des événements médiatiques majeurs (fuites massives, arrestations, réouverture de forums)
- Pics de communication lors de leaks à fort impact ou de conflits publics (BreachForums, affaires gouvernementales)

VI. Analyse linguistique et identification

Recoupement entre pseudonymes, alias et profils associés

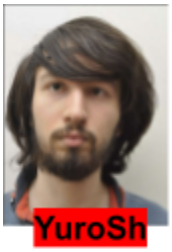
Nom complet : Gabriel Kimiaie Asadi Bildstein

Alias et pseudonymes : Kuroi'SH, Sahrawi Hacker, IrBl00d, kuroi_shg, sh_kuroi, GKimiaie, sh_kuro, Kuroi_dotsh, Mr Green, AMAR^SHG

Affiliations et acteurs cités :

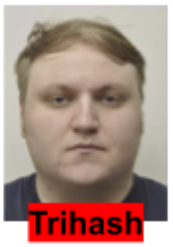
- PoodleCorp
- Intrud3rs
- TouchDownCrew
- GnosticPlayers
- ShinyHunters

Il est principalement connu pour des campagnes de defacement, du DNS hijacking et la compromission de comptes web et réseaux sociaux, avec des cibles comme la NASA, Google ou VEVO. Ses motivations sont surtout idéologiques et politiques, avec des messages pro-palestiniens, mais aussi une forte recherche de reconnaissance. Il travaillait très souvent avec Prosox, les deux apparaissant régulièrement ensemble lors des mêmes opérations.



Nom complet : Adel E. (A.E)

Alias et pseudonymes : YuroSh, Yuro, Yuka, Cvps, Yukari ?



Nom complet : Raphaël L

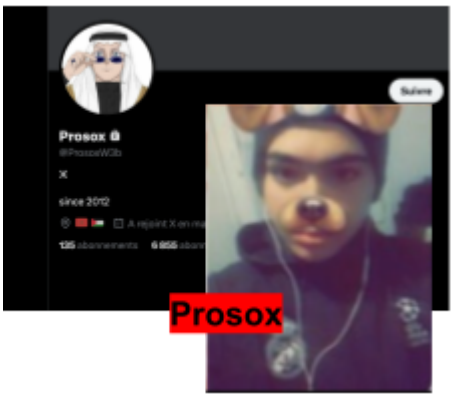
Alias et pseudonymes : Trihash, Hollow

Nom complet : Sébastien Raoult

Alias et pseudonymes : Sezyo Kaizen

Nom complet : "Yanis Urus" **?**

Alias et pseudonymes : Mizaru, M1zaru, Depressed



Nom complet : Nassim Benhaddou

Alias et pseudonymes : ProsoxW3b, Prosoxweb, Prosox, pr0sox, prosoxhacker

Affiliations et acteurs cités :

- Intrud3rs
- ShinyHunters
- TouchDownCrew

Nom complet : Matys Savoie

Alias et pseudonymes : Kelotex, James, K3l0t3x, Gasha, D4rkF0x

Affiliations et acteurs cités :

- SLSH
- ShinyHunters
- Scattered Spider et Lapsus$

Analyse linguistique

Les ShinyHunters communiquent surtout en anglais, mais leur langage est aussi marqué par des expressions typiques de la culture internet, mêlant français et anglais. Le multilinguisme est très présent dans leurs échanges, avec un va-et-vient constant entre les deux langues, particulièrement visible dans les communications de Kelotex alias Matys Savoie.

Etude syntaxique et stylistique des messages publics

La majorité des annonces et des revendications sont faites en anglais, avec un ton professionnel, sur les forums (RaidsForums et BreachForums) Ils présentent toujours leur leaks de manière structurée. Pour gagner en crédibilité, ils fournissent des échantillons de base de données.

Cependant sur les réseaux sociaux (X principalement ainsi que des canaux ou groupes telegram), ils utilisent un ton beaucoup plus provocateur, ils défient les autorités et les entreprises dans le but d'attirer l'attention médiatique.

De plus, sur le site shinyhunters[.]rs, ils utilisent une communication très officielle, ils font des clarifications sur diverses sujets et jouent un rôle de contrôleur narratif en essayant de définir qui sont "vraiment" les ShinyHunters.

VII. Réseau relationnel et partenariats

Identification d'acteurs affiliés ou collaborateurs

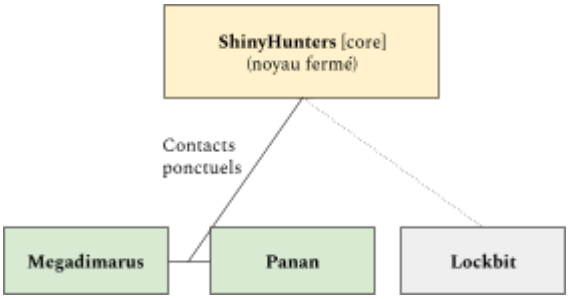
Dans ses premières versions, SH collabore très peu avec d'autres groupes, voire pas du tout. Le noyau fondateur fonctionne surtout en interne, avec une logique fermée et peu d'ouverture vers l'extérieur.

Quelques noms apparaissent néanmoins de manière ponctuelle, notamment Megadimarus et Panan, qui semblent avoir eu des liens occasionnels avec ShinyHunters, sans jamais faire partie du groupe à part entière. Des mentions de collaborations avec des groupes comme LockBit ont aussi circulé, mais aucun élément concret ne permet de confirmer une coopération réelle.

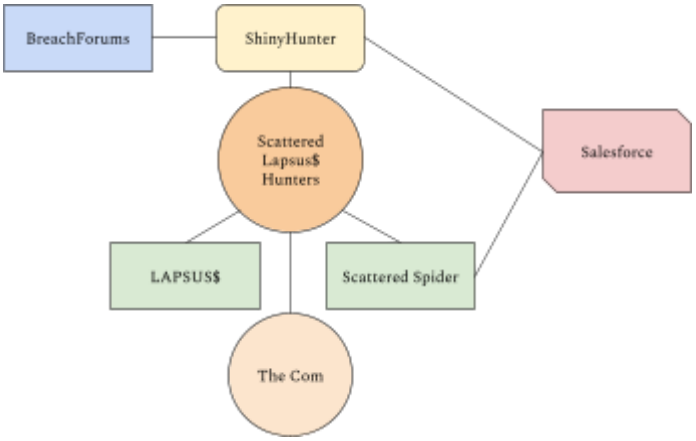
Ce fonctionnement évolue avec le temps. À partir des versions plus récentes du nom ShinyHunters, on observe davantage de liens revendiqués ou supposés avec d'autres acteurs, notamment autour de Scattered Spider et LAPSUS$.

Cartographie des connexions

Phase initiale



Phase SLH



Degré d'influence et hiérarchisation du réseau

Durant sa phase initiale ShinyHunters opérait comme un groupe niche spécialisée dans l'exfiltration. Son influence reposait principalement sur la qualité technique de ses intrusions et le volume massif de ses bases de données. Le groupe était à cette époque dépendant des forums tiers pour sa visibilité.

Avec l'évolution vers l'alliance SLH, un pied dans l'administration de BreachForums ainsi qu'une couverture médiatique bien plus importante la notoriété de ShinyHunters augmente. Le groupe industrialise l'exfiltration en lançant le RaaS ShinySp1der.

Hiérarchie de SLH

L'alliance repose plus sur une complémentarité de compétences et un partage des techniques pour assurer une chaîne complète d'attaque que sur une réelle hiérarchie.

ShinyHunters
Rôle : Exfiltration massive de données, gestion de l'infrastructure et les enchères .

Scattered Spider :
Rôle : Spécialisé dans l'ingénierie sociale et accès initiaux (vishsing, usurpation d'identité, ..)

LAPSUS$
Rôle : (Gestion de la mise en scène des attaques sur les réseaux sociaux.)

VIII. Analyse technique et TTP (ShinyHunter OG)

Techniques observées

- Exploitation de dépôts GitHub publics ou mal sécurisés pour identifier des clés API, identifiants cloud et secrets exposés.
- Analyse systématique de repositories afin d'obtenir un accès non autorisé à des bases de données ou environnements cloud.
- Exploitation de buckets de stockage cloud mal configurés ou exposés publiquement.
- Compromission de sites web, outils de développement et pipelines CI/CD pour récupérer des identifiants et clés d'accès.
- Utilisation de secrets volés comme entry-point vers des services cloud et systèmes.
- Réalisation de campagnes de phishing se faisant passer pour des services légitimes (ex : GateHub).
- Collecte d'identifiants via de fausses pages d'authentification.
- Diffusion, revente ou échange des données volées sur des forums underground et plateformes du dark web.

Outils identifiés

- MZR V2 (MIZARU), outil lié à un membre confirmé de ShinyHunters, utilisé pour scanner des dépôts Git exposés, cloner des repositories et extraire automatiquement des credentials cloud
- Seyzo-v2, outil lié à un membre confirmé de ShinyHunters, utilisé pour exploiter des dépôts Git via git-dumper et collecter des credentials cloud, SMTP et API

Monétisation

- Revente de bases de données pour des montants compris entre 500 et 5 000 USD
- Partage gratuit de certains datasets afin de renforcer la crédibilité sur les forums underground, et positionnement comme agrégateur et revendeur de données compromises

Référentiel MITRE ATT&CK

Les tactiques, techniques et procédure (TTP) observées chez ShinyHunters peuvent être mappées sur le référentiel MITTRE ATT&CK comme suit :

Tactique	ID	Nom de la technique	Description
Reconnaissance	T1589.001 T1589.002 T1598	Gather Victim Identity Information (Credentials / Email addresses) Phishing for Information	Collecte d'informations sur les victimes, incluant identifiants, adresses email et données contextuelles via reconnaissance ouverte et phishing.
Initial Access	T1566 T1078.002 T1078.004	PhishingValid Accounts (Domain / Cloud Accounts)	Obtention de l'accès initial par hameçonnage ou réutilisation de comptes valides compromis dans des environnements cloud ou d'entreprise.
Credential Access	T1528	Steal Application Access Tokens	Vol de jetons d'accès applicatifs afin de contourner les mécanismes d'authentification et accéder aux services cloud.
Discovery	T1580	Cloud Infrastructure Discovery	Identification et cartographie des ressources cloud accessibles après compromission.
Lateral Movement	T1210 T1072	Exploitation of Remote ServicesSoftware Deployment Tools	Déplacement latéral via l'exploitation de services distants ou l'abus d'outils de déploiement logiciel.
Collection	T1530 T1213	Data from Cloud Storage ObjectData from Information Repositories	Collecte de données stockées dans des buckets cloud, dépôts de code et bases de données.
Exfiltration	T1567	Exfiltration Over Web Service	Exfiltration des données volées via des services web afin de contourner les mécanismes de détection réseau.

IX. Evaluation analytique :

Interprétation des données recueillies

Au départ, l'hypothèse principale était que ShinyHunters correspondait à un seul et même groupe, avec des périodes d'inactivité liées aux arrestations ou à la pression judiciaire. Les recherches menées montrent au contraire que ShinyHunters est un nom qui a évolué dans le temps, avec plusieurs versions successives. Le groupe d'origine a progressivement disparu, remplacé par d'autres acteurs qui ont repris le nom sans en partager la structure, les méthodes ou les objectifs. À l'heure actuelle, la version souvent appelée "ShinyHunters" n'a plus grand-chose à voir avec le noyau initial.

Hypothèses sur les motivations et objectifs

Pour le groupe d'origine, les motivations étaient principalement financières. L'objectif était de voler et revendre des bases de données, avec parfois une recherche de notoriété, notamment à travers des cibles visibles.
Pour la version plus récente portée par Kelotex, la motivation semble différente. Le gain financier reste présent, mais la recherche de visibilité, de reconnaissance et de contrôle symbolique (communication, mises en scène, conflits publics, reprise de plateformes) prend une place centrale. Cette évolution marque un passage d'une logique opportuniste à une logique plus orientée vers le pouvoir et la notoriété.

Limites de l'enquête et fiabilité des sources

L'enquête repose surtout sur des sources ouvertes et accessibles publiquement. Pour compléter et vérifier certaines informations, on s'est aussi appuyés sur des rapports de threat intelligence déjà existants et reconnus comme fiables, notamment issus de GTI, Mandiant ou Intel471. Ces ressources sont normalement accessibles uniquement via des licences professionnelles payantes, auxquelles nous avons eu accès dans un cadre académique ou professionnel, sans pouvoir en extraire directement le contenu.

Il faut aussi prendre en compte que l'écosystème étudié est très instable, avec beaucoup de désinformation, d'usurpations d'identité et de conflits internes entre acteurs. Certaines attributions restent donc à nuancer. Les conclusions présentées correspondent à l'état des informations au moment de l'analyse et peuvent évoluer avec le temps.

Annexes

Sources (liens, captures, références) :

https://fr.wikipedia.org/wiki/ShinyHunters
https://www.bleepingcomputer.com/
https://dailydarkweb.net/
https://haveibeenpwned.com/PwnedWebsites
https://socradar.io/blog/dark-web-profile-shinyhunters/
https://securityaffairs.com/186528/security/resecurity-caught-shinyhunters-in-honeypot.html
https://blog.eclecticiq.com/shinyhunters-calling-financially-motivated-data-extortion-group-targeting-enterprise-cloud-applications
https://databreaches.net/2025/08/08/shinyhunters-sent-google-an-extortion-demand-shiny-comments-on-current-activities/
https://unit42.paloaltonetworks.com/shinyhunters-ransomware-extortion/
https://www.ic3.gov/CSA/2025/250912.pdf
https://raw.githubusercontent.com/PaloAltoNetworks/Unit42-timely-threat-intel/refs/heads/main/2025-11-21-IOCs-for-ShinySp1d3r-ransomware.txt
https://www.intel471.com/blog/shinyhunters-data-breach-mitre-attack
https://www.resecurity.com/blog/article/doomsday-for-cybercriminals-data-breach-of-major-dark-web-foru
https://www.resecurity.com/blog/article/shinyhunters-launches-data-leak-site-trinity-of-chaos-announces-new-ransomware-victims
https://flare.io/learn/resources/chaotic-scattered-shiny-lapsus-spider/
https://www.cyberbit.com/news/scattered-lapsus-hunters-slh-merger/
https://breached.company/shinyhunters-the-evolution-of-a-cybercrime-empire-from-pokemon-inspired-hackers-to-global-threat/
https://blog.eclecticiq.com/shinyhunters-calling-financially-motivated-data-extortion-group-targeting-enterprise-cloud-applications
https://x.com/DarkWebInformer/status/1966300784426877282/
https://web.archive.org/web/20251221001851/https://shinyhunte.rs/
https://www.picussecurity.com/resource/blog/scattered-lapsus-hunters-2025s-most-dangerous-cybercrime-supergroup
https://levelblue.com/blogs/spiderlabs-blog/scattered-lapsuss-hunters-anatomy-of-a-federated-cybercriminal-brand
https://x.com/sebastienRaoult/status/2009654896971170240
https://x.com/sebastienRaoult/status/2009654894521634858
https://breachforums.bf/Thread-Unofficial-Database-Index-French-edition--183062
https://thehackernews.com/2025/08/cybercrime-groups-shinyhunters.html
https://www.seqrite.com/fr/blog/anatomy-of-the-red-hat-intrusion-crimson-collective-and-slsh-extortions/

https://x.com/sebastienRaoult/
https://x.com/sebastienRaoult/status/1471438187394383873

Liens possibles / contextuels

Akashi IT	AnonVsilver	Boy Sh	H31	His0k4	KamTieZ	**KiraRoot (@_KiraRoot)**
AloneBoy (@SenpaiWeb)	Black Sniper	Green Ghost	H4x0r	HolaKo	**Kelotex Gasha aka K3L0T3X**	Sxtz (@KunSxtz)
Lou Sh	Moh Ooasiic	**MoroccanWolf**	Muhmad Emad	**RxR**	**ShadeHaxor (@ShadeHaxor)**	**Shin0bi**
Sys Ghost	TCracker	TheMVT	Virus OS	Xepher (@XepherWeb)		

Ces acteurs sont souvent mentionnés dans les messages de revendication ou apparaissent dans des opérations communes, sans pour autant former un groupe structuré et stable.